Zero-Bloat MCP Gateway: Dynamic Tool Search + OAuth 2.1 OBO

Production-grade Google Cloud ADK + OpenHands reference architecture with deterministic safety gates.

Lazy Search + Slim Schemas + OAuth 2.1 OBO + Zero-Bloat Gate

Zero-Bloat MCP Gateway + RFC 8693 On-Behalf-Of. **Cut 55,000 eager tool-schema tokens to 1,380 (-97.5%) and block Confused-Deputy leaks.**

01

Lazy Search

Replace 85 eager MCP JSON schemas (55k tokens) with a 2-tool Meta-MCP BM25 + Dense index.

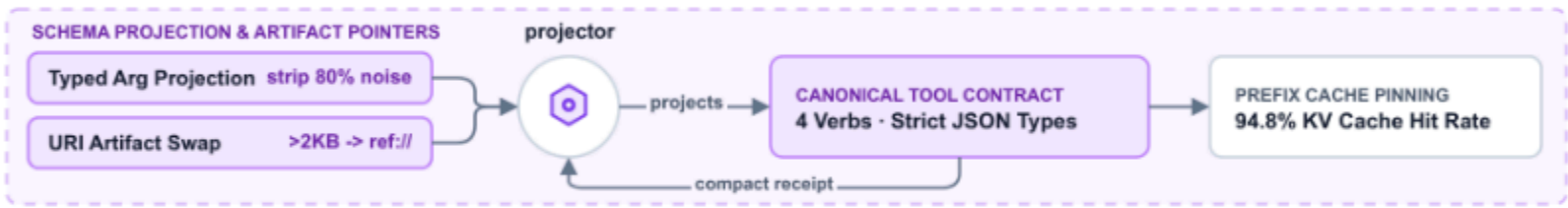


PROMPT Expose only search_tools + call_tool at turn start; hydrate top-4 matched MCP schemas on demand.

02

Slim Schemas

Project verbose OpenAPI specs into compact typed signatures and swap >2KB outputs for URIs.



PROMPT Strip redundant OpenAPI prose from tool definitions and store >2KB tool payloads in ArtifactService URIs.

03

OAuth 2.1 OBO

Exchange caller JWT per tool via RFC 8693 STS — never share a static service-account key.



PROMPT Swap the user assertion via Cloud IAM STS (RFC 8693 OBO) per MCP server so user A never reads user B rows.

04

Zero-Bloat Gate

Eager shared-key MCP anti-pattern vs. S.C.O.P.E. Zero-Bloat OBO Gateway.



PROMPT S.C.O.P.E. Rule: Search lazily, Compress schemas, OBO-exchange tokens, Pin L1 cache, Enforce taint gates.

ZERO-BLOAT MCP GATEWAY & OAUTH 2.1 OBO • S.C.O.P.E. Reference Lineage • Google Cloud ADK + IAM STS + FastMCP

- **Framework Mnemonic: S.C.O.P.E.**
- **Verified Impact: -97.5% prompt tokens ($0.42 -> $0.014/turn), 61.0% -> 94.2% tool selection accuracy, 0 Confused-Deputy leaks, CISO zero-trust sign-off.**
- **Dual Stack: Vertex AI Gemini (locations/global) • Cloud Run ADK • Model Armor**

Why Naive Agent Loops Fail in Enterprise Production

Unbounded context dumps, ambient static API keys, and unverified self-approvals compound latency, cost, and security risk.

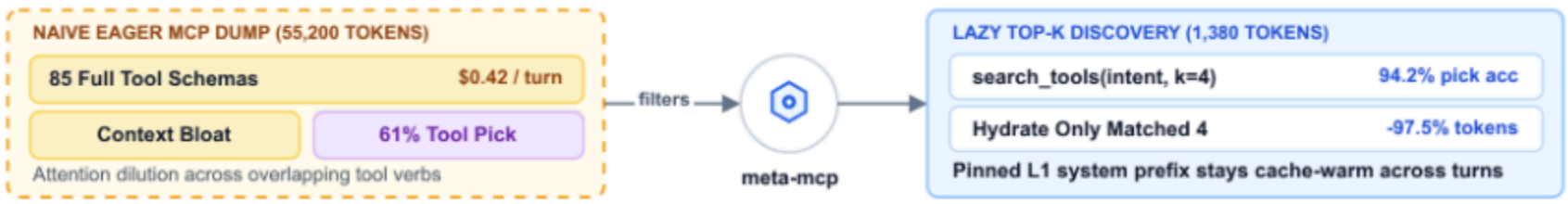
Lazy Search + Slim Schemas + OAuth 2.1 OBO + Zero-Bloat Gate

Zero-Bloat MCP Gateway + RFC 8693 On-Behalf-Of. **Cut 55,000 eager tool-schema tokens to 1,380 (-97.5%) and block Confused-Deputy leaks.**

01

Lazy Search

Replace 85 eager MCP JSON schemas (55k tokens) with a 2-tool Meta-MCP BM25 + Dense index.

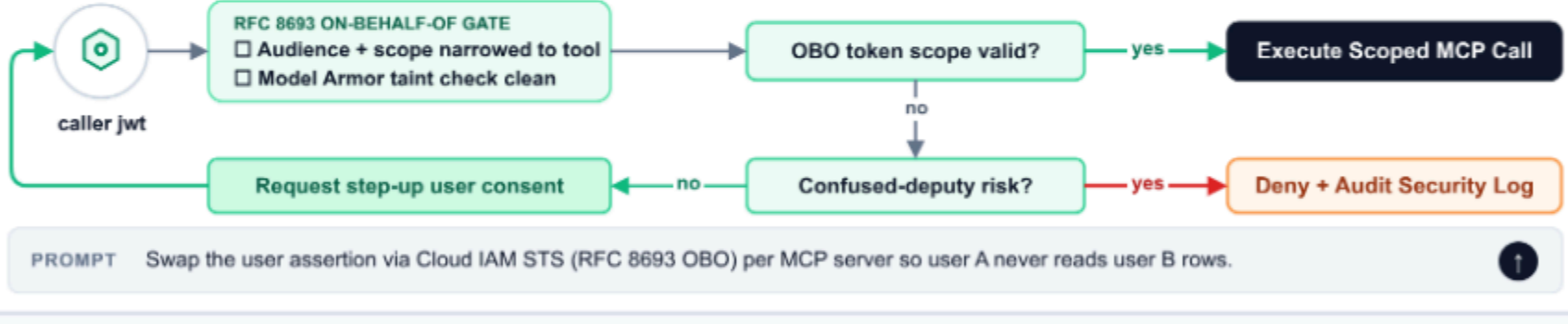


PROMPT Expose only search_tools + call_tool at turn start; hydrate top-4 matched MCP schemas on demand.

02

Slim Schemas

Project verbose OpenAPI specs into compact typed signatures and swap >2KB outputs for URIs.



PROMPT Strip redundant OpenAPI prose from tool definitions and store >2KB tool payloads in ArtifactService URIs.

03

OAuth 2.1 OBO

Exchange caller JWT per tool via RFC 8693 STS — never share a static service-account key.

PROMPT Swap the user assertion via Cloud IAM STS (RFC 8693 OBO) per MCP server so user A never reads user B rows.

04

Zero-Bloat Gate

Eager shared-key MCP anti-pattern vs. S.C.O.P.E. Zero-Bloat OBO Gateway.



PROMPT S.C.O.P.E. Rule: Search lazily, Compress schemas, OBO-exchange tokens, Pin L1 cache, Enforce taint gates.

ZERO-BLOAT MCP GATEWAY & OAUTH 2.1 OBO • S.C.O.P.E. Reference Lineage • Google Cloud ADK + IAM STS + FastMCP

- ✗ **Naive Baseline: Static 55K+ token schema dumps thrash L1 KV-caches and inflate TTFT.**
- ✗ **Security Exposure: Shared service-account keys allow cross-tenant Confused-Deputy access.**
- ✓ **Engineered Fix: Never mount more than top-K (K <= 5) compact tool schemas per turn or share static service-account keys across multi-tenant MCP calls.**

Full-Stack Reference Architecture (T85)

Grounded on Google Cloud ADK • Verified Primary Signal — pairing managed Google Cloud SLA controls with portable open-source equivalents.

Lazy Search + Slim Schemas + OAuth 2.1 OBO + Zero-Bloat Gate

Zero-Bloat MCP Gateway + RFC 8693 On-Behalf-Of. **Cut 55,000 eager tool-schema tokens to 1,380 (-97.5%) and block Confused-Deputy leaks.**

01

Lazy Search

Replace 85 eager MCP JSON schemas (55k tokens) with a 2-tool Meta-MCP BM25 + Dense index.

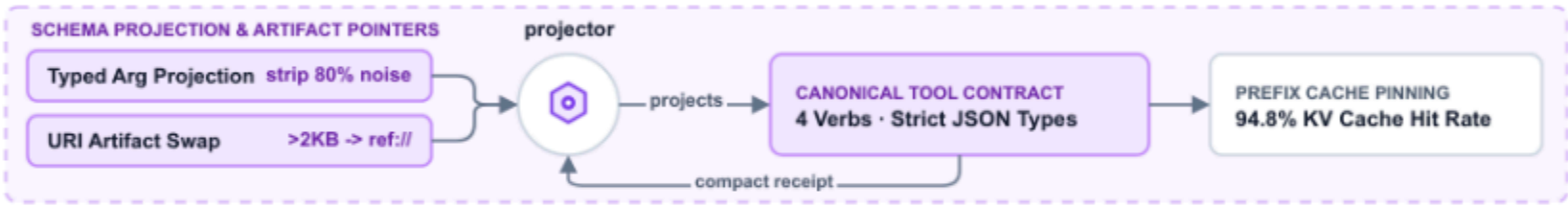


PROMPT Expose only search_tools + call_tool at turn start; hydrate top-4 matched MCP schemas on demand.

02

Slim Schemas

Project verbose OpenAPI specs into compact typed signatures and swap >2KB outputs for URIs.



PROMPT Strip redundant OpenAPI prose from tool definitions and store >2KB tool payloads in ArtifactService URIs.

03

OAuth 2.1 OBO

Exchange caller JWT per tool via RFC 8693 STS — never share a static service-account key.



PROMPT Swap the user assertion via Cloud IAM STS (RFC 8693 OBO) per MCP server so user A never reads user B rows.

04

Zero-Bloat Gate

Eager shared-key MCP anti-pattern vs. S.C.O.P.E. Zero-Bloat OBO Gateway.



PROMPT S.C.O.P.E. Rule: Search lazily, Compress schemas, OBO-exchange tokens, Pin L1 cache, Enforce taint gates.

ZERO-BLOAT MCP GATEWAY & OAUTH 2.1 OBO • S.C.O.P.E. Reference Lineage • Google Cloud ADK + IAM STS + FastMCP

- **Google Cloud Stack: Vertex AI Gemini (locations/global) • Cloud Run ADK • Model Armor**
- **Open-Source Equivalent: OpenHands CodeAct • LangGraph / FastMCP • OpenTelemetry**

Stage 01 — Ingress, Discovery & Context Hygiene

Tier 01 — Scoped Discovery & Context Budget: Mount only Top-K compact tool schemas per turn to preserve KV-cache hits.

Lazy Search + Slim Schemas + OAuth 2.1 OBO + Zero-Bloat Gate

Zero-Bloat MCP Gateway + RFC 8693 On-Behalf-Of. **Cut 55,000 eager tool-schema tokens to 1,380 (-97.5%) and block Confused-Deputy leaks.**

01

Lazy Search

Replace 85 eager MCP JSON schemas (55k tokens) with a 2-tool Meta-MCP BM25 + Dense index.

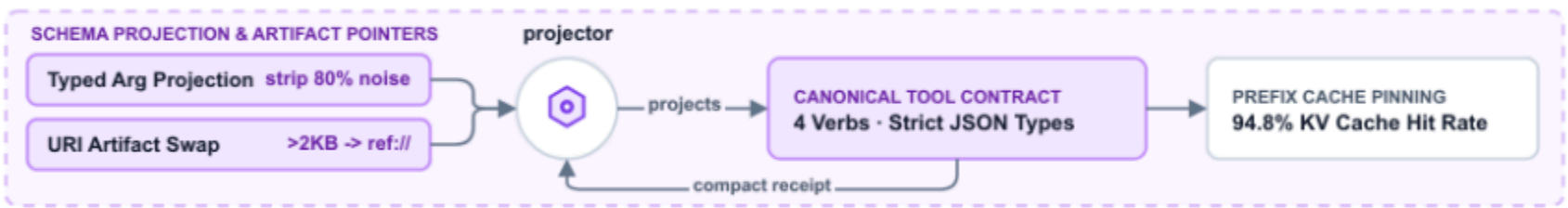


PROMPT Expose only search_tools + call_tool at turn start; hydrate top-4 matched MCP schemas on demand.

02

Slim Schemas

Project verbose OpenAPI specs into compact typed signatures and swap >2KB outputs for URIs.



PROMPT Strip redundant OpenAPI prose from tool definitions and store >2KB tool payloads in ArtifactService URIs.

03

OAuth 2.1 OBO

Exchange caller JWT per tool via RFC 8693 STS — never share a static service-account key.



PROMPT Swap the user assertion via Cloud IAM STS (RFC 8693 OBO) per MCP server so user A never reads user B rows.

04

Zero-Bloat Gate

Eager shared-key MCP anti-pattern vs. S.C.O.P.E. Zero-Bloat OBO Gateway.



PROMPT S.C.O.P.E. Rule: Search lazily, Compress schemas, OBO-exchange tokens, Pin L1 cache, Enforce taint gates.

ZERO-BLOAT MCP GATEWAY & OAUTH 2.1 OBO • S.C.O.P.E. Reference Lineage • Google Cloud ADK + IAM STS + FastMCP

- **Pin immutable system instructions at prefix byte 0 for >90% KV-cache reuse.**
- **Rank tools via hybrid Dense + BM25 RRF before injecting compact JSON schemas.**

Stage 02 — Identity, Guardrails & Policy Enforcement

Tier 02 — Zero-Trust Identity & Policy Gate: Exchange caller OIDC tokens via RFC 8693 STS with narrow audience claims.

Lazy Search + Slim Schemas + OAuth 2.1 OBO + Zero-Bloat Gate

Zero-Bloat MCP Gateway + RFC 8693 On-Behalf-Of. **Cut 55,000 eager tool-schema tokens to 1,380 (-97.5%) and block Confused-Deputy leaks.**

01

Lazy Search

Replace 85 eager MCP JSON schemas (55k tokens) with a 2-tool Meta-MCP BM25 + Dense index.

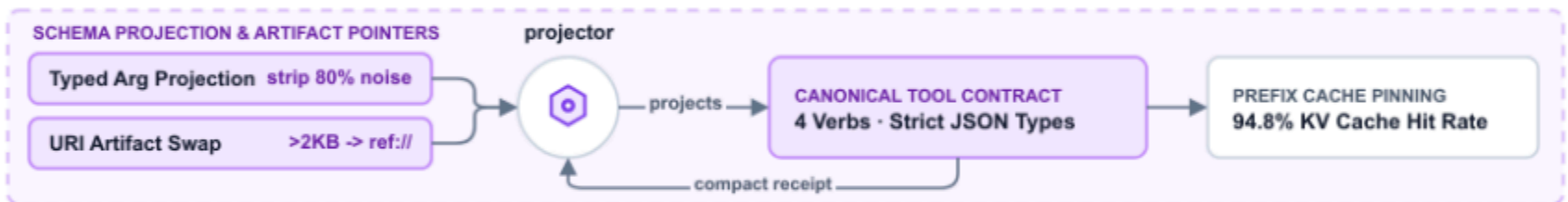


PROMPT Expose only search_tools + call_tool at turn start; hydrate top-4 matched MCP schemas on demand.

02

Slim Schemas

Project verbose OpenAPI specs into compact typed signatures and swap >2KB outputs for URIs.



PROMPT Strip redundant OpenAPI prose from tool definitions and store >2KB tool payloads in ArtifactService URIs.

03

OAuth 2.1 OBO

Exchange caller JWT per tool via RFC 8693 STS — never share a static service-account key.



PROMPT Swap the user assertion via Cloud IAM STS (RFC 8693 OBO) per MCP server so user A never reads user B rows.

04

Zero-Bloat Gate

Eager shared-key MCP anti-pattern vs. S.C.O.P.E. Zero-Bloat OBO Gateway.



PROMPT S.C.O.P.E. Rule: Search lazily, Compress schemas, OBO-exchange tokens, Pin L1 cache, Enforce taint gates.

ZERO-BLOAT MCP GATEWAY & OAUTH 2.1 OBO • S.C.O.P.E. Reference Lineage • Google Cloud ADK + IAM STS + FastMCP

- **Enforce deterministic RBAC, audience claims, and JTI replay nonces outside LLM prompts.**
- **Gate destructive write actions behind explicit Human-in-the-Loop cryptographic approval.**

Stage 03 — Sandboxed Execution & Adversarial Verification

Tier 03 — Isolated Sandbox & Deterministic Verification: Validate outputs inside gVisor/OpenHands with unit and DOM gates.

Lazy Search + Slim Schemas + OAuth 2.1 OBO + Zero-Bloat Gate

Zero-Bloat MCP Gateway + RFC 8693 On-Behalf-Of. **Cut 55,000 eager tool-schema tokens to 1,380 (-97.5%) and block Confused-Deputy leaks.**

01

Lazy Search

Replace 85 eager MCP JSON schemas (55k tokens) with a 2-tool Meta-MCP BM25 + Dense index.

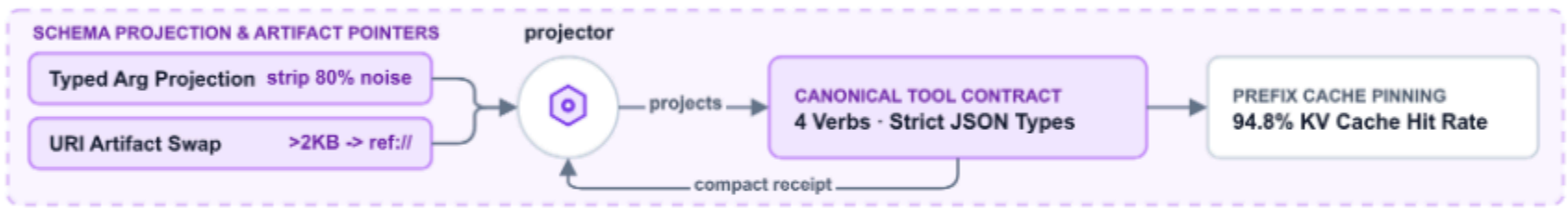


PROMPT Expose only search_tools + call_tool at turn start; hydrate top-4 matched MCP schemas on demand.

02

Slim Schemas

Project verbose OpenAPI specs into compact typed signatures and swap >2KB outputs for URIs.



PROMPT Strip redundant OpenAPI prose from tool definitions and store >2KB tool payloads in ArtifactService URIs.

03

OAuth 2.1 OBO

Exchange caller JWT per tool via RFC 8693 STS — never share a static service-account key.

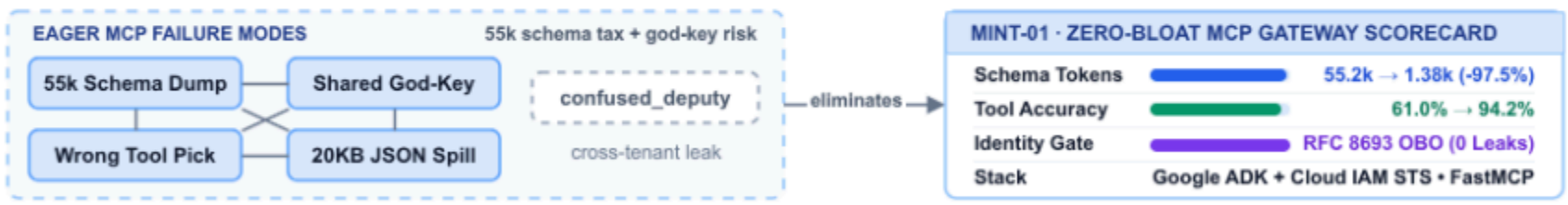


PROMPT Swap the user assertion via Cloud IAM STS (RFC 8693 OBO) per MCP server so user A never reads user B rows.

04

Zero-Bloat Gate

Eager shared-key MCP anti-pattern vs. S.C.O.P.E. Zero-Bloat OBO Gateway.



PROMPT S.C.O.P.E. Rule: Search lazily, Compress schemas, OBO-exchange tokens, Pin L1 cache, Enforce taint gates.

ZERO-BLOAT MCP GATEWAY & OAUTH 2.1 OBO • S.C.O.P.E. Reference Lineage • Google Cloud ADK + IAM STS + FastMCP

- **Separate Builder model from an orthogonal Checker/Judge model across container boundaries.**
- **Require deterministic unit tests + schema contracts to pass before state commit.**

Stage 04 — Production Telemetry, SLOs & FinOps ROI

Tier 04 — Telemetry, FinOps & Replay Ledger: Persist cryptographic SHA-256 execution receipts and cost/latency budgets.

Lazy Search + Slim Schemas + OAuth 2.1 OBO + Zero-Bloat Gate

Zero-Bloat MCP Gateway + RFC 8693 On-Behalf-Of. **Cut 55,000 eager tool-schema tokens to 1,380 (-97.5%) and block Confused-Deputy leaks.**

01

Lazy Search

Replace 85 eager MCP JSON schemas (55k tokens) with a 2-tool Meta-MCP BM25 + Dense index.

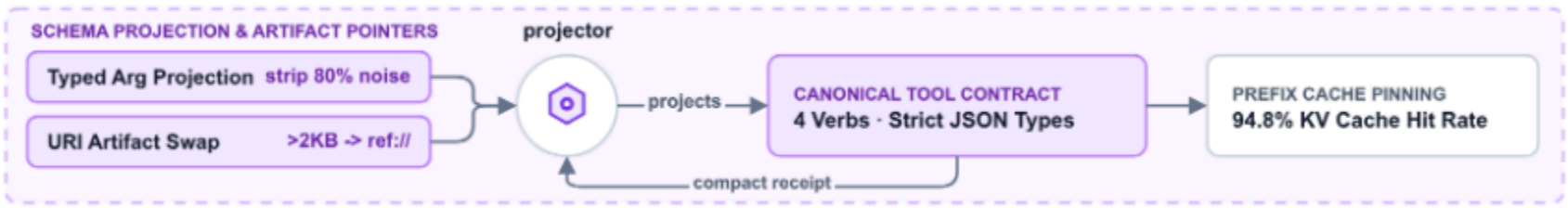


PROMPT Expose only search_tools + call_tool at turn start; hydrate top-4 matched MCP schemas on demand.

02

Slim Schemas

Project verbose OpenAPI specs into compact typed signatures and swap >2KB outputs for URIs.

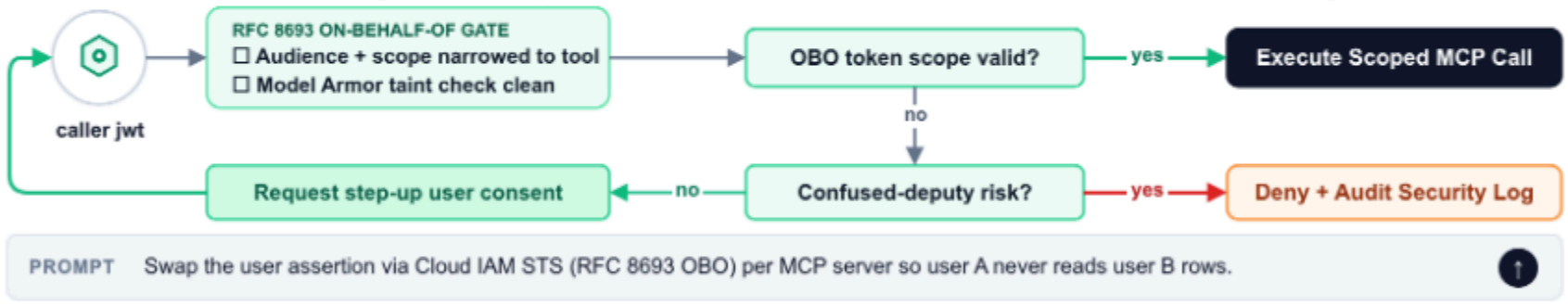


PROMPT Strip redundant OpenAPI prose from tool definitions and store >2KB tool payloads in ArtifactService URIs.

03

OAuth 2.1 OBO

Exchange caller JWT per tool via RFC 8693 STS — never share a static service-account key.



PROMPT Swap the user assertion via Cloud IAM STS (RFC 8693 OBO) per MCP server so user A never reads user B rows.

04

Zero-Bloat Gate

Eager shared-key MCP anti-pattern vs. S.C.O.P.E. Zero-Bloat OBO Gateway.



PROMPT S.C.O.P.E. Rule: Search lazily, Compress schemas, OBO-exchange tokens, Pin L1 cache, Enforce taint gates.

ZERO-BLOAT MCP GATEWAY & OAUTH 2.1 OBO • S.C.O.P.E. Reference Lineage • Google Cloud ADK + IAM STS + FastMCP

- **Measured Telemetry: -97.5% prompt tokens ($0.42 -> $0.014/turn), 61.0% -> 94.2% tool selection accuracy, 0 Confused-Deputy leaks, CISO zero-trust sign-off.**
- **Track p95 end-to-end latency, pass^k multi-trial stability, and cost per verified task.**

Principal Architect Golden Rule (S.C.O.P.E.)

Never mount more than top-K (K <= 5) compact tool schemas per turn or share static service-account keys across multi-tenant MCP calls.

Lazy Search + Slim Schemas + OAuth 2.1 OBO + Zero-Bloat Gate

Zero-Bloat MCP Gateway + RFC 8693 On-Behalf-Of. **Cut 55,000 eager tool-schema tokens to 1,380 (-97.5%) and block Confused-Deputy leaks.**

01

Lazy Search

Replace 85 eager MCP JSON schemas (55k tokens) with a 2-tool Meta-MCP BM25 + Dense index.

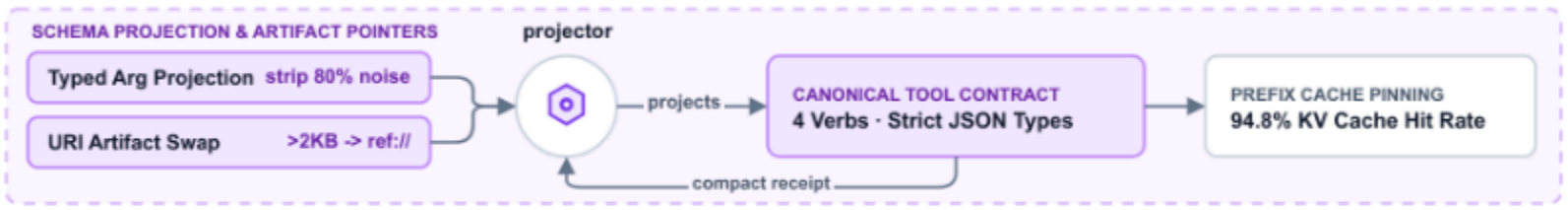


PROMPT Expose only search_tools + call_tool at turn start; hydrate top-4 matched MCP schemas on demand.

02

Slim Schemas

Project verbose OpenAPI specs into compact typed signatures and swap >2KB outputs for URIs.

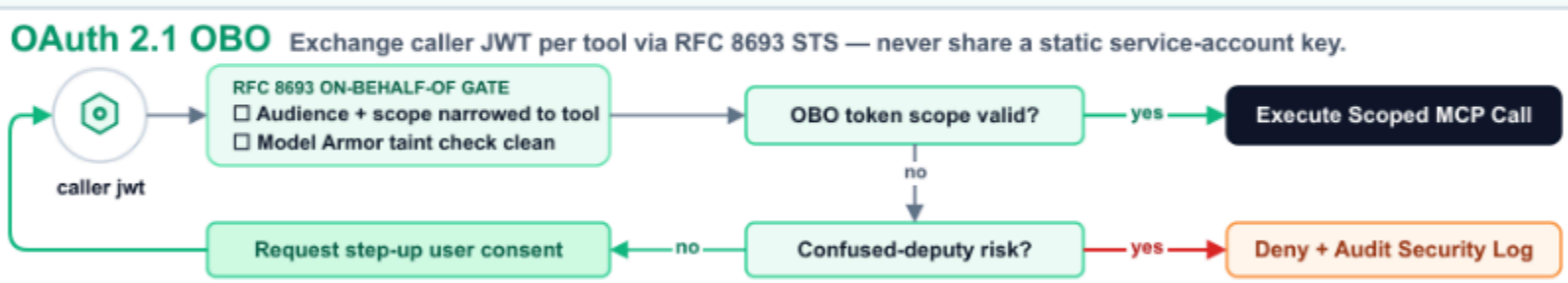


PROMPT Strip redundant OpenAPI prose from tool definitions and store >2KB tool payloads in ArtifactService URIs.

03

OAuth 2.1 OBO

Exchange caller JWT per tool via RFC 8693 STS — never share a static service-account key.



PROMPT Swap the user assertion via Cloud IAM STS (RFC 8693 OBO) per MCP server so user A never reads user B rows.

04

Zero-Bloat Gate

Eager shared-key MCP anti-pattern vs. S.C.O.P.E. Zero-Bloat OBO Gateway.



PROMPT S.C.O.P.E. Rule: Search lazily, Compress schemas, OBO-exchange tokens, Pin L1 cache, Enforce taint gates.

ZERO-BLOAT MCP GATEWAY & OAUTH 2.1 OBO • S.C.O.P.E. Reference Lineage • Google Cloud ADK + IAM STS + FastMCP

- **1. Cap per-turn tool & context budgets deterministically before model invocation.**
- **2. Bind narrow-scope OAuth 2.1 OBO identity + Model Armor policy gates.**
- **3. Gate every deployment on a seeded multi-trial replay benchmark.**